

Relay Attacks in Intra-handshake Attestation

Muhammad Usama Sardar^{1,2}, Viacheslav Dubeyko³,
and Jean-Marie Jacquet⁴

(ACK: Eric Rescorla, Juho Forsén, Markus Rudy, Mariam Moustafa,
Tjaden Hess, Yuning Jiang, Pavel Nikonorov, and Casey Wilson)

¹TU Dresden, Germany

²Co-chair, Trusted Research Environment (TRE) Open Suite,
Global Alliance for Genomics and Health (GA4GH)

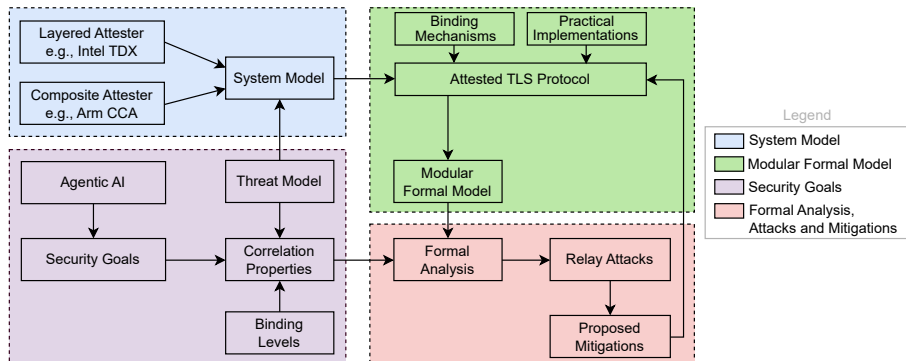
³IBM, San Jose, CA, USA

⁴Nadi Research Institute, University of Namur, Belgium

February 10, 2026

Quick Recap of Approach¹

- TLS 1.3 as example transport protocol
- Agentic AI as example use case
- Formalization tool: ProVerif



¹<https://mailarchive.ietf.org/arch/msg/rats/6gbqx0XY8WYrH3Mx4v08n2-uKgY/>

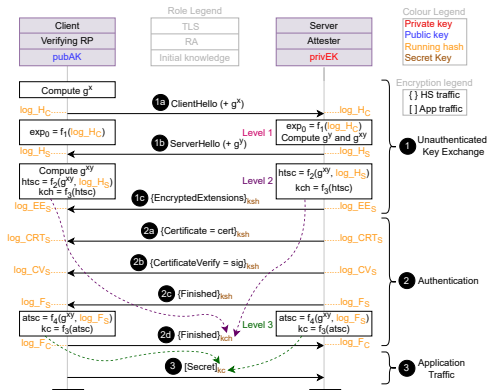
Potential Mechanisms for Binding (TLS Server as Attester)

S. No.	Binding material	Value of rdata field
1	Client's TLS nonce	nc
2	Client's attestation nonce	na
3	Early exporter	exp_0
4	Server's public key	pubEK
5	Client's attestation nonce and early exporter	na exp_0
6	Client's attestation nonce and server's public key	na pubEK
7	Nonce, server's public key, and early exporter	na pubEK exp_0

- **Discussion:** Any other useful binding material/combination?
- Example implementations: all are vulnerable
 - #1: Meta's AI (even after [extensive security review](#) by TrailOfBits without formal methods)
 - No Evidence freshness
 - #5: draft-fossati-tls-attestation-06
 - #6: Edgeless Systems Contrast, Cocos AI and CCC PoC²
- **Discussion:** Any other intra-handshake implementation?

²<https://github.com/CCC-Attestation/attested-tls-poc>

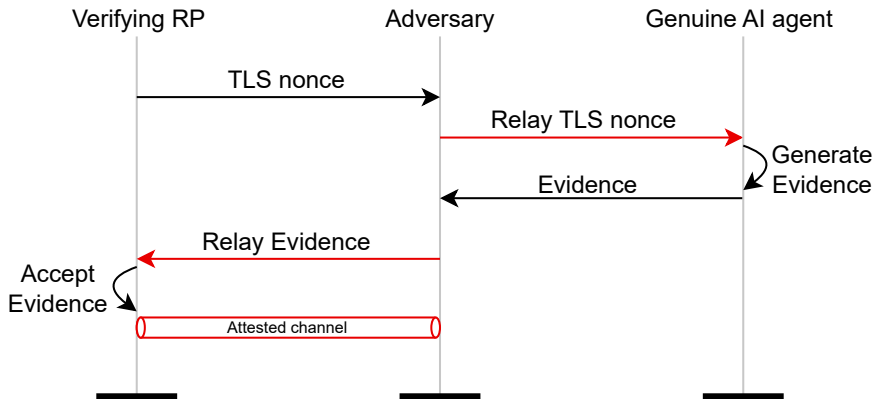
Devil is in the Details!



- htsc : used for encryption of clientFinished message (2d).
 - Irrelevant for security goals
 - Server **not yet authenticated** at this point
- atasc : used for encryption of application data (client's secret, e.g., decryption key)
 - Relevant for security goals

Relay Attack 1 (Abstracted): Mechanism # 1 (nc)

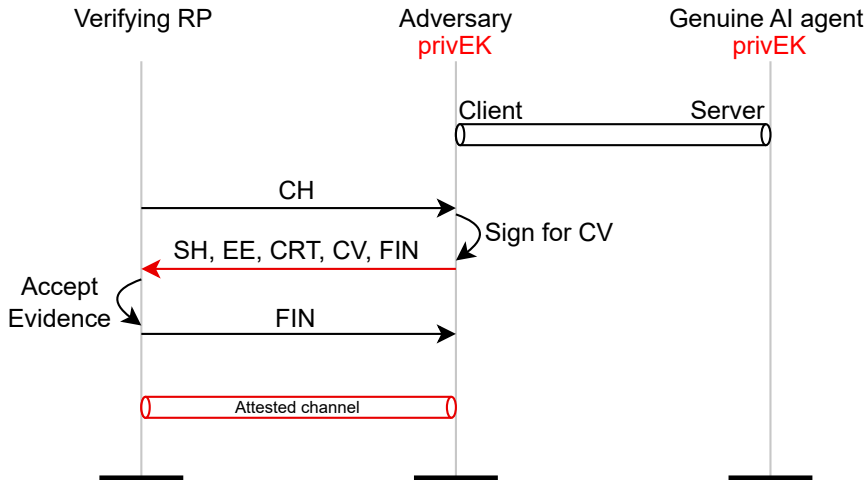
- Analogous to the one presented in IETF 124 meeting³
- Adversary can **relay** nonce to a genuine Attester



³<https://datatracker.ietf.org/meeting/124/materials/slides-124-rats-sessb-guideline-for-security-consideration-of-rats-00>

Relay Attack 2 (Abstracted): Mechanism # 4 (pubEK)

- No protection if **privEK** is accessible to some entity other than an AI agent (e.g., provisioning at runtime)
- Adversary gets signed Evidence from genuine AI agent



May be beyond TLS

- We believe that attacks are beyond just TLS and **fundamental security consideration** of RA
 - Preliminary analysis indicates same problem in **attested EDHOC**
 - May apply to **Noise** too!
 - Core problem: Binding Evidence to unauthenticated peer (Server/Responder)
- Mitigation: use post-handshake attestation